UNIVERSIDADE ESTADUAL DE MARINGÁ
DEPARTAMENTO DE INFORMÁTICA
Disciplina: 11926 – Desenvolvimento de Sistemas Seguros
Curso: Bacharelado em Informática
Professora: Luciana A. F. Martimiano

TRABALHO PRÁTICO COM FERRAMENTAS PARA ANÁLISE DE VULNERABILIDADES EM APLICAÇÕES WEB

O trabalho pode ser feito por um trio ou por uma dupla.

Valor: 0,0 a 10,0 (100% da nota da Avaliação 3), sendo 20% da apresentação e 80% do relatório.

Data final de entrega do relatório (via Classroom): 04/12/2025.

Datas para a apresentação: 09 e 11/12/2025.

Objetivos:

- Instalar e executar as ferramentas SQLMap, OWASP Zap e Burp Suite.
- Realizar análises de vulnerabilidades em pelo menos duas aplicações Web diferentes.
- Discutir as formas de mitigação das vulnerabilidades encontradas pelas ferramentas, conforme documentos disponíveis em https://cheatsheetseries.owasp.org/index.html e https://owasp.org/www-project-top-ten/.

As ferramentas podem ser utilizadas a partir do **sistema operacional Kali Linux** (https://www.kali.org/). A URL **http://testphp.vulnweb.com** e o sistema *Damn Vulnerable Web Application* (DVWA) (https://github.com/digininja/DVWA) podem ser utilizados para a execução das ferramentas. O site https://www.vulnhub.com/ possui outras aplicações vulneráveis. **Caso a equipe queira, pode utilizar uma aplicação Web real. No entanto, os responsáveis pela aplicação devem estar de acordo**. Um termo de autorização (ao final deste documento) deve ser assinado pelo(s) responsável(is) concordando com os testes. **Ressalto que vocês NÃO podem executar análise de vulnerabilidades ou testes de invasão sem autorização.**

Ao final das análises, elaborem um **relatório detalhado** com as principais funcionalidades de cada ferramenta e com os resultados dos testes. Usem *screenshots* das ferramentas para o relatório.

O relatório deve conter os seguintes itens (entre 20 e 30 páginas): resumo, introdução descrevendo a importância do desenvolvimento de aplicações Web seguras, da análise de vulnerabilidades e de testes de invasão, descrição breve do Kali Linux e das ferramentas utilizadas, análise dos resultados dos testes, conclusão crítica e referências.

Segue uma breve descrição das ferramentas.

A) SQLMap

Esta ferramenta automatiza o processo de detecção e exploração de vulnerabilidades de *SQL Injection* em aplicações Web. Além de oferecer funções de detecção e exploração de *SQL Injection*, o SQLMap é capaz de "dominar" o sistema de banco de dados desde que seja possível. A ferramenta também pode atuar em um ponto determinado para que seja verificado se este ponto permite com que o banco de dados seja explorado. A ferramenta funciona apenas por linhas de comando.

Inicialmente, é necessário fornecer a URL da página Web que contenha uma variável vulnerável. Ao obter essa URL, a mesma é inserida como um parâmetro na chamada da ferramenta, seguida do comando "--dbs" para mostrar o banco de dados encontrado, caso o mesmo esteja vulnerável - sqlmap –u http://testphp.vulnweb.com/search.php?test= --dbs.

Em seguida, reaproveita-se o comando anterior removendo o parâmetro "--dbs", inserindo o parâmetro "-D", acrescentando o banco de dados escolhido e em seguida o comando "--tables"; assim, são mostradas as tabelas daquele banco de dados.

Novamente reaproveita-se o comando anterior, removendo o parâmetro "--tables", incluindo o parâmetro "-T", nome da tabela, e o parâmetro "--columns"; assim, são mostradas as colunas daquela tabela.

Por fim, novamente o comando anterior é reaproveitado, removendo o parâmetro "--columns", inserindo "-C", as colunas desejadas separadas por vírgula e entre aspas simples, e o parâmetro "--dump". Isso irá mostrar todo o conteúdo das colunas especificadas, como por exemplo, *logins* e senhas de usuários cadastrados.

B) OWASP-Zap (Zed Attack Proxy)

A *OWASP-Zap* foi desenvolvida pelo OWASP (*Open Web Application Security Project; http://www.owasp.org/*) para encontrar vulnerabilidades em aplicações Web. A *Zap* realiza testes automatizados de invasão, fazendo com que sejam verificados todos os vetores de ataque possíveis dentro de uma aplicação Web, e caso alguma falha seja encontrada, é mostrado onde ela está localizada, qual o tipo de falha de segurança e o nível de gravidade que esta falha traz.

A ferramenta possui interface gráfica intuitiva. Na tela principal existe um campo "*URL to attack*", no qual é inserido o endereço da página ou aplicação web que se deseja explorar.

C) **Burp Suite**

O Burp Suite oferece uma plataforma integrada para identificar, explorar e corrigir vulnerabilidades em aplicações Web. A plataforma combina ferramentas automatizadas e recursos avançados de análise para testes de segurança. Suas principais funcionalidades são:

- Interceptação de Tráfego;
- Análise de Vulnerabilidades;
- Testes de Invasão;
- *Scanner* de Segurança;
- Ferramentas de Repetição de Requisições.

Universidade Estadual de Maringá
Centro de Tecnologia
Departamento de Informática

TERMO DE AUTORIZAÇÃO

Eu, _____, concordo e autorizo que o(s) alunos(as) _____, RA(s) _____, regulamente matriculados(as) na disciplina 11926 – Desenvolvimento de Sistemas Seguros - do curso de Bacharelado em Informática da Universidade Estadual de Maringá, utilizem meu domínio ou minha aplicação para realizar análise de vulnerabilidades com as ferramentas <nomear as ferramentas>.

Domínio autorizado (URL): _____

Aplicação autorizada (URL): _____

Maringá, ___ de _____de 2025.

_____

Nome e Assinatura